

Medidas de seguridad – prevención de incidentes

Seguridad física

Consiste en proponer medidas de seguridad para **proteger**:

- El **equipamiento** (robo de discos, sabotaje del cableado, cortes de suministro)
- Las **personas**
- Los **espacios**

De nada sirve aplicar muchas medidas de seguridad lógica si el atacante tiene acceso físico a los sistemas (¿Dejarías a un hacker a solas con tu portátil 5 min?).

Las **principales amenazas para la seguridad física** son:

- **Acceso físico** a los dispositivos (robo de discos, sabotaje de cableado, cortes)
- **Fugas de información** sensible



Las **principales medidas de prevención** para mantener la seguridad física y mitigar estas amenazas son:

- **Seguridad perimetral**: restringir el acceso contra entradas no autorizadas a las instalaciones que contienen los datos a proteger (vallas, protección de ventanas, cerraduras, armarios rack para proteger cableado y servidores, cortafuegos, IPS)
- **Alarmas** anti incendios, anti inundaciones, anti robos: sensores y sistemas de vídeo vigilancia
- **Control de acceso físico** a las zonas restringidas (biometría)
- Medidas para **garantizar la HA** si ocurren desastres naturales como inundaciones, incendios, terremotos, apagones (alarmas, SEI, SAI, clusters)

Los **Data Centers** o CPD (Centro de Procesamiento de Datos) incluyen muchas medidas de seguridad física, ya que son el lugar seguro donde alojar los servidores, sus aplicaciones y los datos.



Ejemplo: cómo es la seguridad física en los Data Centers de Google:

<https://www.youtube.com/watch?v=XZmGGAhHqa0>

<https://www.youtube.com/watch?v=kd33UVZhnAA>



Seguridad lógica

Consiste en proponer medidas para **proteger los datos y los servicios**.

Las empresas deben gestionar la seguridad de su información **definiendo un SGSI** (basado en la norma internacional ISO 27001).

El **SGSI** (Sistema de Gestión de la Seguridad de la Información) **les permitirá**:

- **Identificar** los activos, los riesgos y los posibles ataques
- **Proteger** los sistemas anticipadamente (medidas de prevención – activas)
- **Recuperarse** de ataques sufridos (mitigación o respuesta a incidentes – pasivas)

*Siempre se debe **procurar evitar** los incidentes (prevenir-activa) **antes que** tener que **ejecutar medidas de contingencia** para recuperarse del incidente (curar-pasiva) ya que **ahorrará tiempo, reputación y dinero**.*

Principales medidas de seguridad lógica

El SGSI de la empresa debe proponer medidas de **seguridad lógica** para estos aspectos:

- Gestión de cuentas de usuario y Control de acceso
- Protección de la información y Criptografía
- Copias de seguridad
- Seguridad en el punto final
- Seguridad en la red



• Gestión de cuentas de usuario y Control de acceso

Cada empresa debe administrar las cuentas de usuario y los recursos compartidos en la red.

El **SGSI** de la empresa debe definir una política o **procedimiento** para regular cómo será el **control de acceso** y que incluya:

- Cómo será el **procedimiento de alta y de baja de los usuarios** en los sistemas (eliminar las cuentas de los usuarios que abandonen la empresa)
- Qué **permisos** tendrá **cada usuario o grupo** en los equipos y recursos de red. Se debe usar el principio del *mínimo privilegio*: los usuarios sólo deben tener acceso a la información imprescindible para realizar su trabajo y nada más (por confidencialidad).
- Cómo será el **control de acceso: físico y/o lógico**.
- Qué **complejidad y caducidad** deben tener las **contraseñas** (o 2SA, o biometría)



- Se debe contemplar la Autenticación, Autorización y Auditoría de usuarios (**AAA**):
 - **Autenticación:** el sistema verifica que el usuario es quien dice ser. La autenticación se puede realizar mediante:
 - Algo que el usuario sabe o tiene (una password, un 2SA, una tarjeta ID)
 - Algo que el usuario es (mejor - autenticación biométrica),También se puede aplicar al usuario un *inicio de sesión único* para autenticarse una vez en un sistema maestro y éste le gestiona sus credenciales en otros sistemas sin volver a autenticarse. Se les puede crear una contraseña de un solo uso (OTP – One Time Password) aleatoria y válida una sola vez (suele usarse en 2SA).
 - **Autorización:** comprobar qué permisos de acceso que tiene el usuario.
 - **Auditoría:** almacenar un registro (log) de la actividad del usuario en el sistema
- Qué condiciones de **confidencialidad** debe cumplir el empleado **por contrato**
- Qué **controles** se realizarán **periódicamente** para asegurar que se cumplen los procedimientos anteriores.

Usuarios:

El usuario cumple un **papel muy importante en la seguridad** de los sistemas.

Suele ser el **eslabón más débil** de muchos sistemas de seguridad pese a que usemos varias medidas de seguridad.



Hay que **concienciar y formar a los usuarios** (empleados de la empresa) **para que colaboren** usando los sistemas de manera segura y responsable.

Adicionalmente se deben aplicar **medidas de prevención** para gestionar con seguridad los datos de usuario (*decálogo de la seguridad*):

1. **Actualizar los sistemas:** un equipo vulnerable es atractivo para los atacantes.
2. **Usar contraseñas fuertes** y no usar la misma para varios sistemas. Evitar compartirlas ni escribirlas (mejor usar un gestor de contraseñas para solo tener que recordar una única contraseña muy segura). Mejor usar 2SA.
3. Bloquear la sesión de los equipos y dispositivos (no dejarlos desatendidos).
4. **Cifrar la información confidencial** en unidades de almacenamiento externo (USB).
5. Usar el **sentido común:** no descargar archivos adjuntos desconocidos ni abrir enlaces dudosos.
6. Solo usar **redes de confianza** para acceder a los servicios sensibles como la banca o compras (ojo con las Wi-Fi gratis).
7. **Realizar copias de seguridad** de sus datos con regularidad.
8. **Analizar los dispositivos** que se conecten al equipo. El malware se puede propagar a través de unidades USB infectadas (discos externos, smartphones).
9. **No publicar información personal** en RRSS (puede usarse para ingeniería social).
10. **Controlar nuestras cuentas** para detectar cualquier actividad sospechosa.

· Protección de la información y criptografía

Consiste en **proteger la información importante** para la organización **contra su publicación, corrupción, secuestro o pérdida.**

Se debe tener los posibles estados en los que puede estar la información:

Criptografía, cifrado o encriptación:

Son técnicas para proteger la información **ocultándola** a usuarios no autorizados.

Es una medida de seguridad **activa y lógica** (como las passwords).

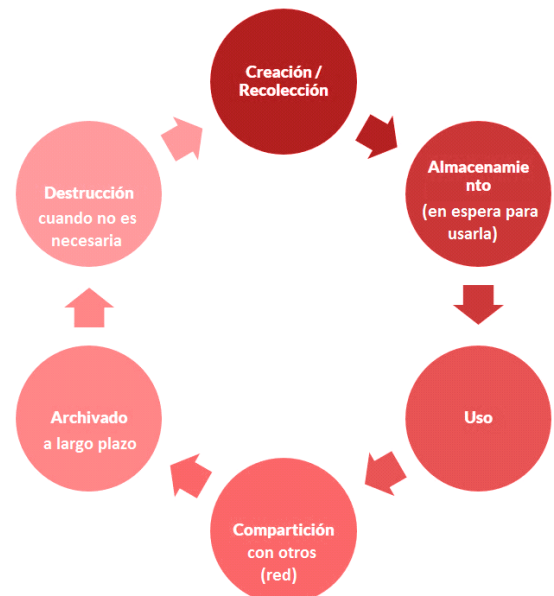
Protege la información de ataques contra su:

- **Confidencialidad:** solo los usuarios autorizados tienen acceso a los datos.
- **Integridad:** garantiza que la información original no será alterada.
- **Autenticación:** permite al sistema verificar si el usuario que pretende hacer uso del sistema es quien dice ser.
- **No repudio:** cuando se envíe o reciba un mensaje, ni el remitente ni el destinatario pueden negar su participación.

Hay varios **técnicas criptográficas** o sistemas de cifrado:

- **Criptografía simétrica** o de clave privada: usa la misma clave para cifrar como para descifrar la información. El inconveniente es que la clave deben tenerla tanto en el emisor como en el receptor, por lo que la clave se debe enviar por un canal seguro.
- **Criptografía asimétrica** o de clave pública: usa dos claves: una clave privada para cifrar y otra clave pública para descifrar. Aunque se conozca la clave pública no se puede calcular la clave privada. Son métodos más complejos, lentos y seguros.
- **Criptografía híbrida - Firma digital:** permite demostrar al receptor del mensaje que el emisor es quien dice ser (autenticación), que no puede negar que envió el mensaje (no repudio) y que el mensaje no ha sido alterado (integridad). La firma digital de un archivo consiste en:
 - Primero crear un resumen o hash (resumen) del archivo
 - Luego encriptarlo con la clave privada. El hash cifrado junto con el archivo es la firma digital que se enviará.

Al recibir el mensaje, si el hash descifrado coincide con el hash calculado de los



datos, entonces asegura que los datos no han cambiado desde que se firmó. Además, la información se puede encriptar cuando los datos están:

- **En tránsito:** cuando es enviada a través de la red (p.e. un correo electrónico por Internet). En este caso conviene usar protocolos de red seguros que encripten la información (HTTPS, SSH, FTPS); así como conexiones cifradas (VPN)



- **En reposo:** cuando está almacenada en un dispositivo. Podemos cifrar ficheros, carpetas e incluso todas las particiones del disco (full disk encryption). En este segundo caso, si el portátil o equipo se pierde/roba, la información contenida no podrá ser accedida simplemente montando el disco en otra máquina.



Ejemplo: www.osi.es/es/actualidad/blog/2019/05/29/cifrado-y-almacenamiento-seguro-de-ficheros-paso-paso

• Copias de seguridad, seguridad en el correo y monitorización

Copias de seguridad:

Un backup es una copia de respaldo que **duplica la información sensible en otro soporte** para poder recuperarlos en caso de fallo del primer almacenamiento.

Es una medida de seguridad **pasiva y lógica** fundamental que **ofrece disponibilidad** de la información.



Se debe detallar un **procedimiento para realizar y recuperar las copias** de seguridad:

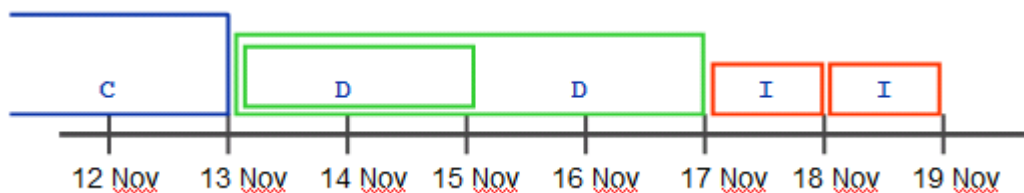
- ¿Qué archivos copiar? (solo lo importante)
- ¿Cómo copiarlos? (tipo de copia: todo o los cambios)
- ¿Cuándo copiarlos? (frecuencia diaria, semanal, mensual)
- ¿Dónde almacenarlo? (NAS, USB, cloud)
- ¿Cuánto tiempo guardar las copias anteriores?
- ¿Se deben comprobar tras realizarse?
- ¿Se deben comprimir?
- ¿Se deben encriptar?
- ¿Cómo restaurarlas en caso necesario? (procedimiento de recuperación)



Existen varios **tipos de copia de seguridad**:

- Copia **espejo** (mirroring): es una copia exacta de los datos originales que se realiza en tiempo real (sincronizando carpetas o con un sistema de dos discos en RAID1). Se usa en sistemas con requisitos de disponibilidad elevados (servidores en producción).
- Copia de seguridad **completa**, íntegra o total: copia todos los archivos del sistema. La primera copia siempre debe ser completa. Es la más lenta y la que más ocupa. Suele realizarse una o dos veces al mes.
- Copia de seguridad **diferencial**: sólo copia los archivos creados o modificados desde la última copia de seguridad completa. Suele realizarse una vez por semana.
- Copia de seguridad **incremental**: sólo copia los archivos creados o modificados desde la última copia de seguridad (de cualquier tipo). Es la más rápida y la que menos espacio ocupa. Suele realizarse una o más veces diarias.

Ejemplo: plan de copias de seguridad con los tres tipos.



• Seguridad en el punto final

Consiste en **proteger los equipos y las aplicaciones** que usa el usuario para evitar que sufran incidentes de seguridad.

Incluye varios aspectos a securizar:



Seguridad en el correo electrónico y en la navegación:

El correo electrónico, la navegación web y las descargas son una de las formas más usuales para **compartir información** entre usuarios y equipos.

Suponen el principal **vector de entrada** para amenazas (phishing, malware...).



En cuanto al **uso del correo electrónico** se debe definir procedimientos para:

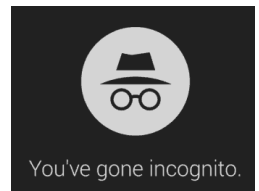
- Detectar los intentos de **phishing**
- **Analizar** los enlaces, las descargas y los archivos adjuntos en busca de malware

- No confiar en emails con archivos **adjuntos de desconocidos**
- **No publicar** las direcciones de correo en sitios web dudosos
- Utilizar **filtros anti-spam** para descartar el correo no deseado
- Usar **contraseñas seguras** para el correo y cambiarlas con frecuencia
- **Cifrar** los emails (servicio de correo web cifrado: protonmail, mailvelope)
- Comprobar si la contraseña de nuestro correo ha sido hackeada:
<https://cybernews.com/personal-data-leak-check> <https://haveibeenpwned.com>
- Usar correos electrónicos temporales para formularios de alta (<https://temp-mail.org>)



En cuanto a la **navegación en sitios web** de Internet se debe definir procedimientos para:

- Usar el **sentido común**: visitar solo sitios web seguros **HTTPS**
- Tener **actualizado el SO, el antivirus y los navegadores** web
- No acceder a sitios web de warez, torrents: propagan malware
- **Impedir la ejecución** de archivos desde sitios web sin verificar
- Descargar programas solo desde el **sitio oficial**
- No instalar **complementos extras** sin verificar su autenticidad
- No acceder a servicios personales (correo, banca, RRSS) desde redes **WiFi públicas** (bibliotecas, aeropuertos, centros comerciales)
- **Eliminar** archivos temporales, cookies, historial, contraseñas (modo incógnito)
- Navegar usando una conexión con un server **VPN**, usar DNS-over-HTTPS (cifrado).
- Elegir **un único navegador** para usar en toda la empresa y mantenerlo actualizado.



Protección contra malware:

Un antivirus (AV) es un programa que **detecta y elimina software malicioso**:

virus, spyware, gusanos, troyanos, rootkits, RATs, keyloggers, mineros, bots, adware, spammers ...



Son una medida de seguridad **lógica** que es **activa y pasiva** a la vez.

Se basan en **buscar firmas** de los virus dentro de los archivos infectados.
Para ello **necesitan actualizar** frecuentemente su base datos de firmas de virus.

Actualmente los virus modifican su firma para no alertar a los AV. Consecuentemente los antivirus se basan en Machine Learning de forma que se les entrena para que detecten

malware con características similares.

Detección de intrusiones (Endpoint Detection & Response):

Se consigue instalando en cada equipo una aplicación de tipo **HIDS** (Host IDS) que **monitoriza el sistema** analizando estos aspectos para detectar posibles ataques:

- Los procesos
- La memoria
- Los archivos en uso
- Las conexiones de red entrantes y salientes, etc,



Configuración segura, hardening, fortificación o bastionado:

Consiste en **configurar** los sistemas y las aplicaciones (firmware, SO, BBDD, aplicaciones, servicios, etc) **para reducir las amenazas** posibles.

Se consigue **aplicando múltiples medidas** para aumentar la seguridad del sistema y de la información contenida:

- Establecer **contraseñas seguras** (o 2SA)
- Asegurar los **permisos de acceso** de usuarios (mínima exposición)
- **Cifrar** la información sensible
- Configurar un **AV**
- **Cerrar puertos** de red innecesarios
- Configurar un **FW**
- Implementar un plan de **backups**



Gestión de vulnerabilidades:

Consiste en **analizar periódicamente los equipos en busca de vulnerabilidades** (agujeros de seguridad) que puedan ser aprovechadas para crear incidentes de ciberseguridad.

Para ello se usan programas **escáners de vulnerabilidades** que buscan vulnerabilidades en los equipos. Las identifican mediante su código **CVE** y su nivel de riesgo (gravedad):



OpenVAS
Open Vulnerability Assessment Scanner



También se usan herramientas de hacking para realizar **tests de penetración** (*pentesting*) que pongan a prueba la seguridad de los

sistemas para descubrir sus vulnerabilidades. Adicionalmente se pueden usar *equipos señuelos* llamados **honeypots**. Estos equipos ejecutan falsos servicios y almacenan datos simulados. Se sitúan en la red local a la espera de que alguien los ataque para luego poder averiguar *quién, cómo, cuándo y por qué* lo hizo. Con esta información se puede mejorar la seguridad de la empresa.



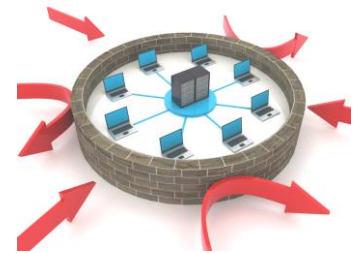
Finalmente **se deben reparar todas las vulnerabilidades** encontradas.

• Seguridad de la red

Las empresas cuentan con una **red local LAN** conectada a una red WAN insegura como **Internet**.

Las conexiones de red son el **principal vector de ataque** por dónde se ejecutan muchas amenazas.

La empresa debe contar con **procedimientos** definidos para un **uso seguro la red**:



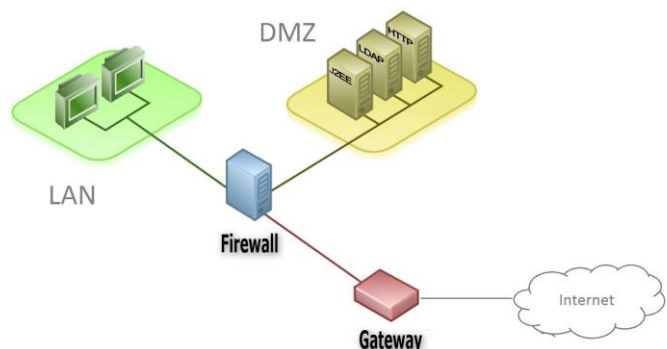
Segmentación de la red local:

Consiste en **dividir una gran red LAN en subredes** (segmentos) más pequeñas y controlables.

Cada subred se corresponderá con un departamento de la empresa.

Se debe exponer en Internet únicamente los equipos locales necesarios (**DMZ**).

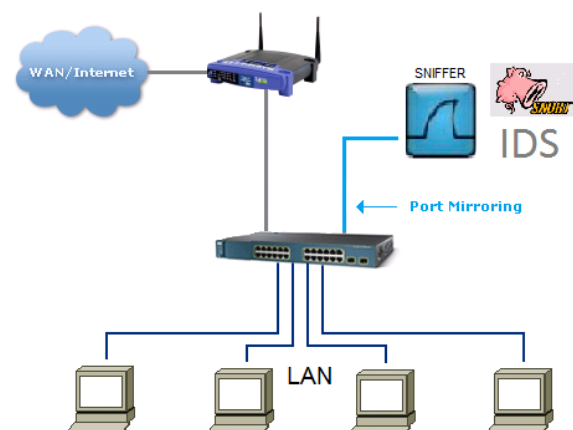
La segmentación se puede realizar de forma física o lógica (usando **VLANS** - redes locales virtuales).



IDS/IPS (Detección/Prevención de intrusiones en red):

Un sistema de detección de intrusos (IDS – Intrusion Detection System) es un programa capaz de **detectar accesos indebidos y ataques en una red local**.

Se trata de una medida **pasiva y lógica**.



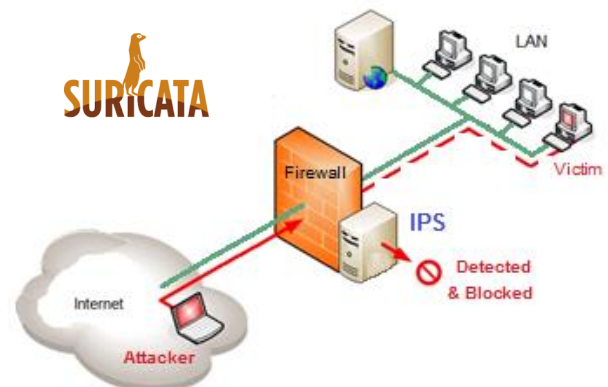
Captura y analiza el tráfico de red para compararlo con firmas de ataques conocidos, o comportamientos sospechosos, como:

- Escaneo de puertos
- Inundaciones de tráfico (DoS)
- Suplantación de direcciones MAC y de direcciones DNS (MitM)

Un **IPS** (Sistema de Prevención de Intrusos) además permite bloquear el tráfico indeseado de con reglas predefinidas en el cortafuegos.

Se trata de una medida **activa y lógica**.

Los sistemas IDS/IPS deben **actualizar periódicamente su base de datos de firmas** como los antivirus para poder detectar los nuevos ataques de red. Los AV e IDS adoptan el Machine Learning para poder detectar ataques mediante análisis de ataques similares.



Cortafuegos (FW):

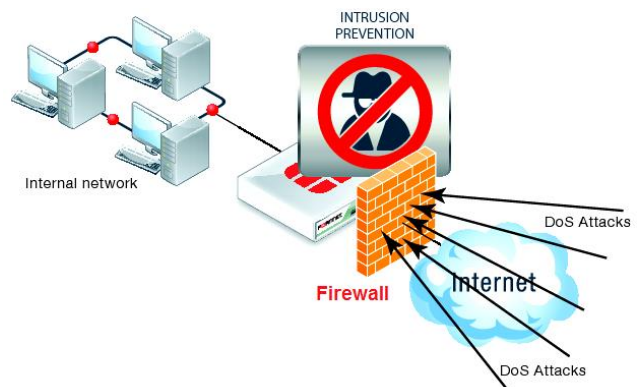
Aplicación que **bloquea los accesos no autorizados** a través de la red.

Se configura en base a **reglas predefinidas que permiten o bloquean los paquetes** de las conexiones de red.

Es una medida **activa y lógica**.

Existen varios **tipos** de firewalls:

- **Sin estado** (bloquean paquetes).
- **Con estado**: tiene una tabla que controla las sesiones creadas (flujo de datos). Sólo necesita crear una regla en un sentido y permite el resto de paquetes de la sesión.
- **Con inspección profunda** de paquetes (**DPI** o Deep Packet Inspection): es un IDS/IPS con un cortafuegos con estado que puede detectar patrones de tráfico más avanzados. Es capaz de asociar sesiones a usuarios de la red y a protocolos para poder filtrar por estos valores.
- **A nivel de aplicación**: filtran conexiones en la capa de aplicación de la arquitectura TCP/IP. Los servidores **Proxy HTTP** bloquean conexiones según la URL indicada. Los **WAF** (Web Application Firewall) protegen aplicaciones web de ataques OWASP.





SIEM (Security Information and Events Management):

Aplicación que **recolecta** de forma centralizada **eventos de seguridad** desde diferentes fuentes de la red (logs del SO, del FW, del IDS, del AV, del VulnerabilityScanner) **para** correlacionarlos, analizarlos y **detectar** posibles intrusiones o **incidentes de seguridad**:

- Dispone de **reglas de alerta** y correlación para notificar posibles intrusiones.
- Dispone de un sistema de **análisis de los eventos** de la red para detectar posibles incidentes que podrían indicar un ataque.
- Permite **integrar la información** necesaria para tomar decisiones que den respuesta a un incidente: eliminar ciertos ficheros, recopilar más información, ordenar al FW un bloqueo, aislar una subred o un equipo, etc.



Ejemplo: implementación de un SIEM en la red local corporativa de una empresa:

